

Google DeepMind's CodeMender automatically detects and corrects software vulnerabilities

Google DeepMind has introduced CodeMender, an artificial intelligence agent designed to automatically detect and patch software vulnerabilities, marking a new phase in AI-driven open source collaboration.

DeepMind confirmed that CodeMender has already upstreamed 72 security fixes to open source projects within six months, working across codebases as large as 4.5 million lines. The company will now seek feedback from open source maintainers on these AI-generated patches to refine the system before a wider release.

Built on Google's Gemini Deep Think models, CodeMender functions as an autonomous debugging agent capable of reasoning about code, applying fixes, and automatically validating them to prevent regressions. All patches undergo human review before submission to maintain consistency and quality control.

Among its early successes, CodeMender uncovered a heap buffer overflow bug linked to faulty XML stack management and improved the libwebp image compression library by enforcing compiler bounds checks that block buffer overflows. DeepMind noted that if such compiler flags had been implemented earlier, the 2023 libwebp vulnerability exploited in an Apple iOS zero-day attack could have been avoided.

DeepMind is preparing detailed technical papers on CodeMender and plans to extend AI's role in cybersecurity, including AI-powered ransomware detection for Google Workspace.

Researchers Jai Minton, James Northey, and Alden Schmidt warned: "This activity highlights how attackers are increasingly abusing new and emerging publicly available tooling... While publicly available tooling can be used legitimately, it is also commonly abused due to low research cost and plausible deniability."



This underscores the dual-use risk of open source tools, demonstrating the need for security teams to monitor OSS projects as potential attack vectors, not just bespoke malware.

Hackers leverage TruffleHog to hunt AWS credentials

Crimson Collective, the threat actor behind a major Red Hat breach, has shifted focus to Amazon Web Services (AWS) cloud environments. The group aims to establish persistence, steal sensitive data, and extort victims for money.

Cybersecurity researchers at Rapid7 observed that the attackers are using the open source secrets scanner TruffleHog to locate exposed AWS credentials. Once validated, these credentials are used to create new IAM users and access keys via API, escalate privileges by attaching policies such as AdministratorAccess, and map the victim's network. Subsequent steps include modifying RDS passwords, creating snapshots, exporting data to S3, and exfiltrating objects before sending extortion demands, sometimes via AWS SES.



The group previously breached Red Hat's private GitLab repositories, exfiltrating approximately 570GB of data from 28,000 internal projects, including 800 customer engagement records (CERs) containing infrastructure, authentication, and operational insights. Such sensitive records amplify the risk for follow-up attacks against Red Hat clients.